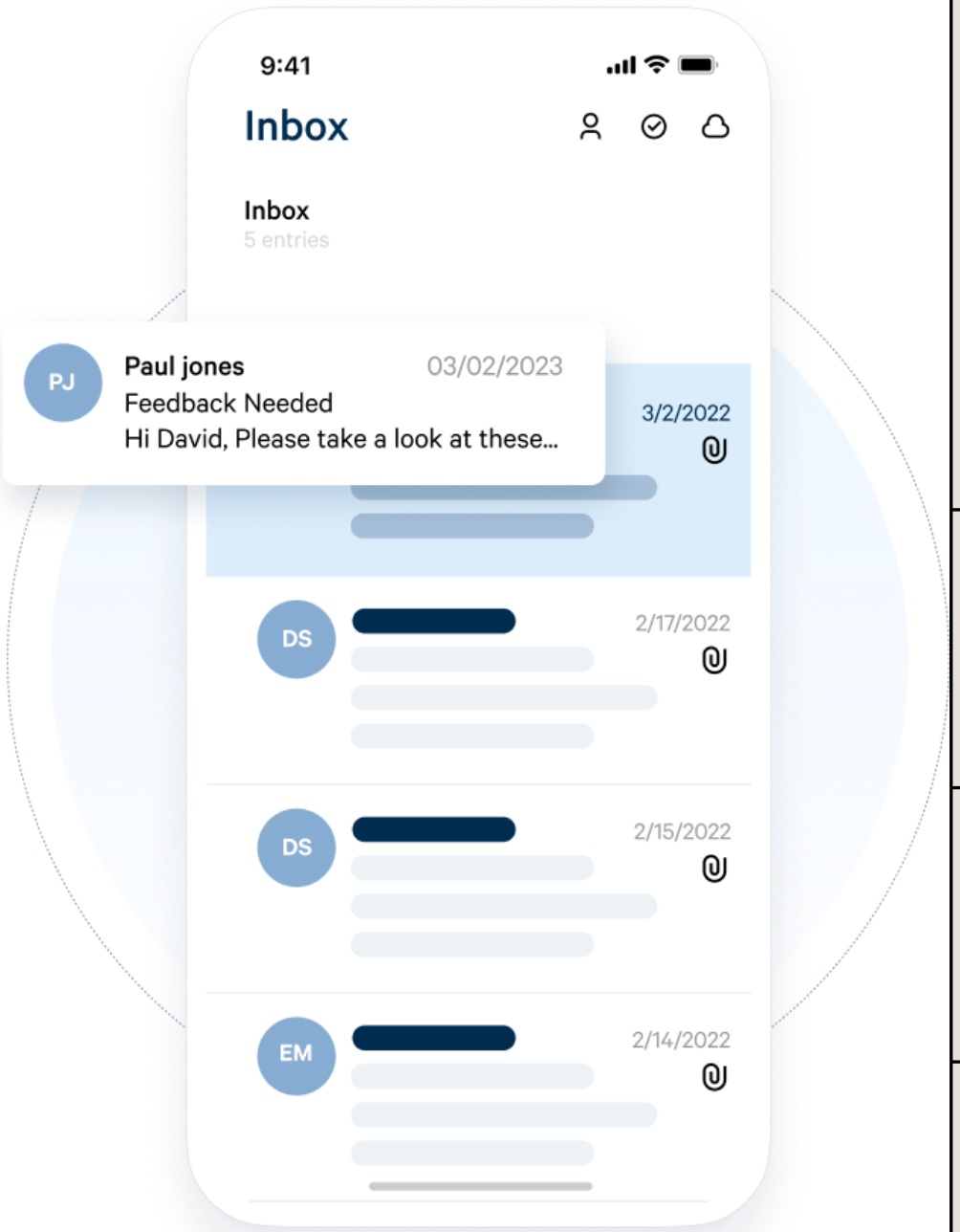
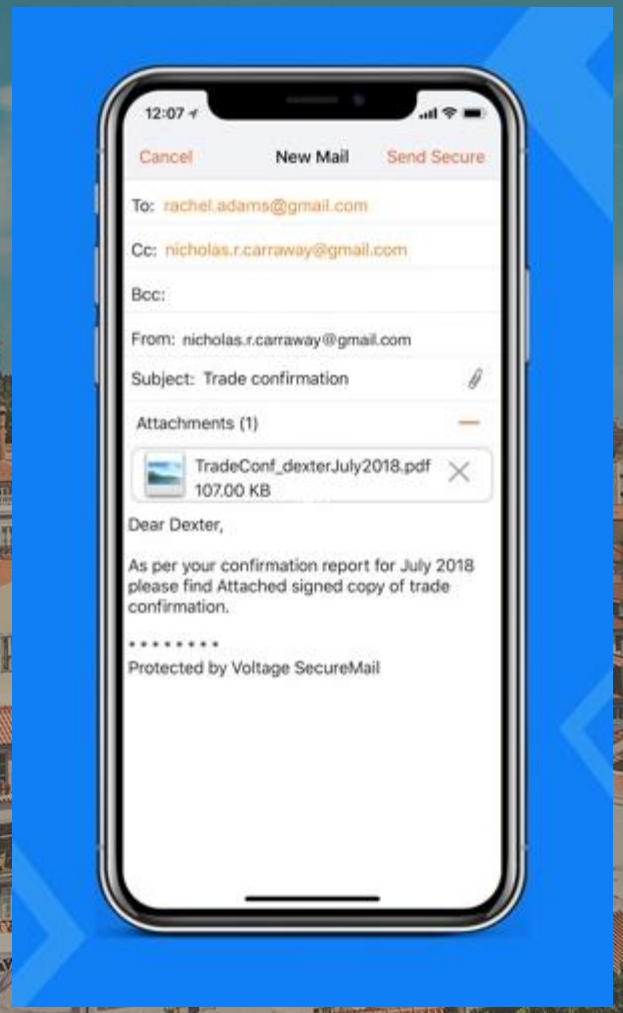


EMAIL, SECURE MAIL, ITS THREATS, DETECTION

A PRESENTATION BY NIKOLA ŠAŠINKOVÁ

PRINCIPLES OF INFORMATION SECURITY

1ST PROGRESS REPORT



AGENDA

- DETAILED PROJECT DESCRIPTION
- EMAIL STRUCTURE
- HEADER FIELD SYNTAX & COMMON ORDER
- WHAT KEY HEADERS MEAN
- ADDRESSES & GROUPS
- RESENDING
- ANALYSIS OF THE SELECTED TOOLS FOR EXPERIMENTATION
- EMAILPROFI SETUP (SEZNAM.CZ) – SPF, DKIM, DMARC
- TYPES OF ATTACKS AND THEIR EXECUTION
- REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS
- SOURCE CODE FOR ANALYZING EMAIL HEADERS IMPLEMENTED IN PYTHON
- PLAN FOR CONTINUING THE PROJECT
- SOURCES

DETAILED PROJECT DESCRIPTION

- **Theory coverage:** email structure (RFC 822), header syntax & key fields, TLS vs E2EE, and attack taxonomy (phishing, spear phishing, spoofing, DoS, trojan horse)
- **Tools & platforms:** EmailProfi domain setup with **SPF** and **DMARC**, **MXToolbox** for DNS, blacklist, header checks, **Mail-Tester** for deliverability score, **Emkei** for fake-sender baseline
- **Configuration & records:** SPF, DMARC configuration and verification, comparison of correct vs incorrect configurations
- **Implementation artifacts:** Python **header analyzer** for *.eml* (From, To, Received, Message-ID, DKIM, SPF…) and Python **email sender** for test messages
- **Experiment design & data:** 3 body types x 4 sender setups = **12 tests** (valid text, GTUBE known-spam, spam-like x personal, domain-correct, domain-incorrect, Emkei)
- **Evaluation & recommendations:** analysis of results, spam filter description, practical safety tips, screenshots, tables, complete documentation, final source code

EMAIL STRUCTURE

- An email = **Headers + Body** (the body can be empty)
- **Separator:** one **blank line** between headers and body
- **Headers are ASCII lines:** field-name ":" [field-body] CRLF
- **Folding:** a long header may continue on the next line that **starts with a space or tab**
- **Unfolding:** when reading, join them back into one line
- **Order:** headers can be in **any order**, the body **must** come after all headers
- **Body:** US-ASCII text, **no lone CR or LF**, **≤ 998 chars per line** (CRLF not counted)

EXAMPLE:

```
From: Alice <alice@example.com>
To: Bob <bob@example.net>
Subject: Hello world
Date: Wed, 10 Oct 2025 10:15:00 +0200

This is the message body.
```

HEADER FIELD SYNTAX & COMMON ORDER

- **Header field syntax (RFC 822):**

  field = field-name ":" [field-body] CRLF
  field-name = 1*<any CHAR except CTLs, SPACE, ":">
  field-body = <ASCII chars> (can be folded)
- **Common recommended order:**
  Return-Path -> Received -> Date -> From -> Subject -> Sender -> To -> Cc -> Bcc -> Reply-To
- **"Received" chain:** each server that relays the mail **adds one Received line**, the **top** one is **newest**
- **Return-Path:** added by the **final transport** (where bounces/errors go)

FOLDING EXAMPLE

Subject: Quarterly results for Q3,
including region-by-region details

UNFOLDING EXAMPLE

Subject: Quarterly results for Q3, including region-by-region details

WHAT KEY HEADERS MEAN

Header	Purpose	Who sets it	Example value
Return-Path	**Where delivery errors/bounces go**	Final mail server	*<mailer-daemon@example.net>*
Received	**Hop-by-hop trace of servers**	Each relay server	*from mx1.example.com by mx2.example.net ...*
Date	**When the author sent the message**	Author's mail app	*Wed, 10 Oct 2025 10:15:00 +0200*
From	**The author of the message**	Author	*Alice <alice@example.com>*
Subject	**Short summary**	Author	*Quarterly Results Q3*
Sender	**Authenticated sender (if different from From)**	App/author	*noreply@service.sk*
To	**Main recipients**	Author	*Bob <bob@example.net>, team@example.org*
Cc	**Secondary recipients (visible)**	Author	*finance@example.org*
Bcc	**Hidden recipients**	Author	*manager@example.com (often only in author's copy)*
Reply-To	**Where replies should go**	Author	*support@example.com*

ADDRESSES & GROUPS

- **Address forms**
  - **Mailbox (name-address):** Display Name <local-part@domain>
    Example: Nikola Sasinkova nikola.sasinkova@gmail.com
  - **Mailbox (addr-spec only):** local-part@domain
    Example: nikinka@nikuska.cz
  - **Group of mailboxes:** Display Name ":" [mailbox, mailbox, ...] ";"
    Example: Team Alpha: alice@example.com, bob@example.net;

- **addr-spec parts**
  - addr-spec = local-part "@" domain
  - local-part = quoted-string | dot-atom (e.g., nikola.sasinkova)
  - domain = dot-atom | domain-literal (e.g., gmail.com or [127.0.0.1])

EXAMPLE

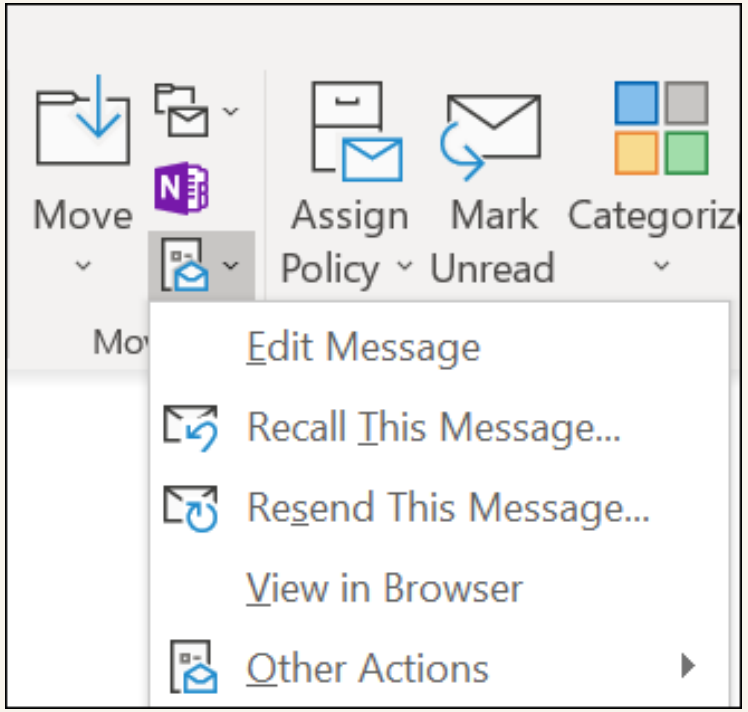
To: "Team Alpha": Alice <alice@example.com>, Bob <bob@example.net>;
Cc: Charlie <charlie@example.org>

RESENDING

- **Resending, forwarding (headers)**
  - When **resending** a message, add headers like:
    Resent-Date, Resent-From, Resent-To
  - These show **who resent it** and **to whom**, the original **From** stays the original author

EXAMPLE

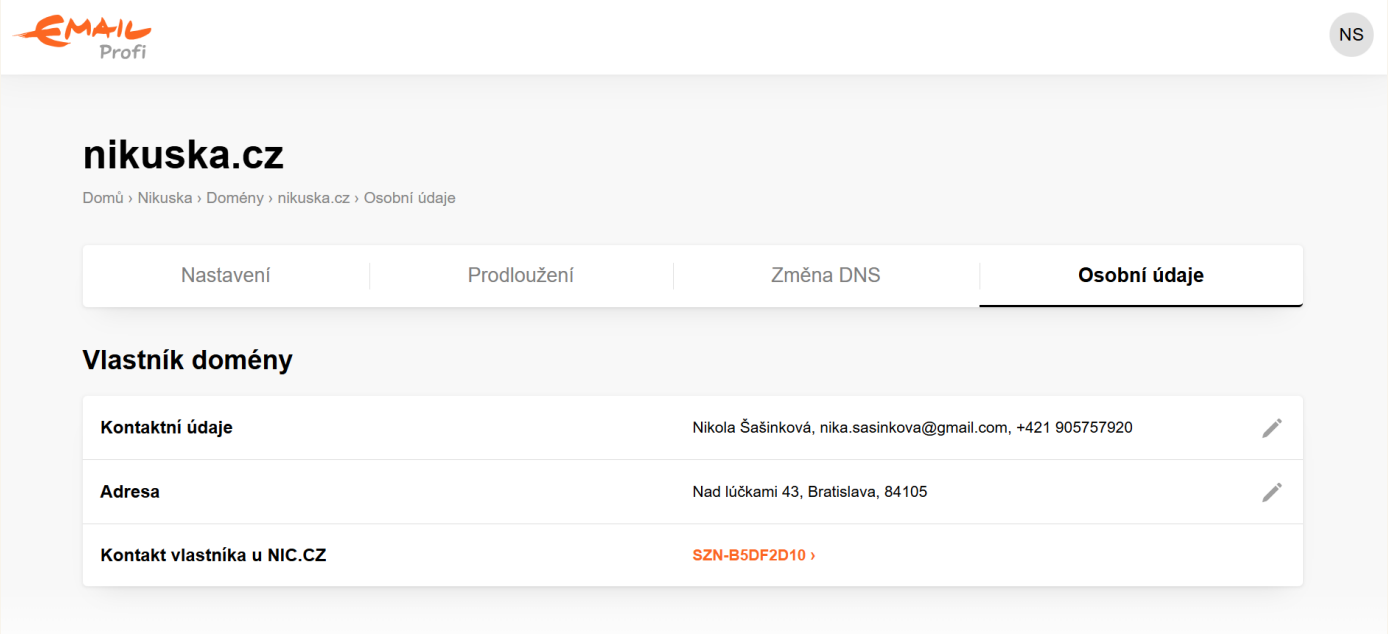
Resent-Date: Wed, 10 Oct 2025 10:15:00 +0200
Resent-From: Admin <admin@example.org>
Resent-To: Bob <bob@example.net>



ANALYSIS OF THE SELECTED TOOLS FOR EXPERIMENTATION

EMAILPROFI

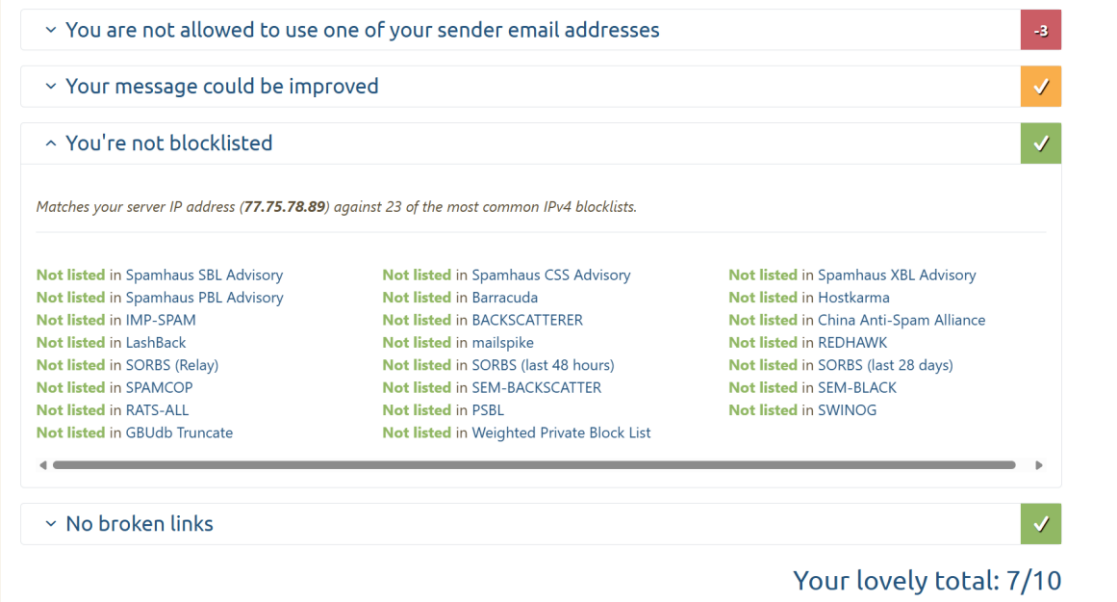
- **What it is:** email hosting for own domain with Seznam webmail, **unlimited mailboxes & storage**, calendar, and anti-spam
- **Connect existing domain:** sign in -> Add new domain -> enter domain -> accept license & I own a domain -> generate MX records -> update DNS -> create mailbox
- **Register new domain:** sign in -> Add new domain -> enter new **.cz** name -> accept license -> buyer info -> purchase
- **Pros:** unlimited users & storage, familiar Seznam interface, calendar, support for mobile & desktop clients
- **Cons:** need to **buy a domain** if you don't have one, tied to Seznam infrastructure (if Seznam has downtime or policy changes, email could be affected), must manage **MX records and DNS correctly**, wrong **SPF/DMARC** -> mail may be flagged as spam or rejected



ANALYSIS OF THE SELECTED TOOLS FOR EXPERIMENTATION

MAIL-TESTER

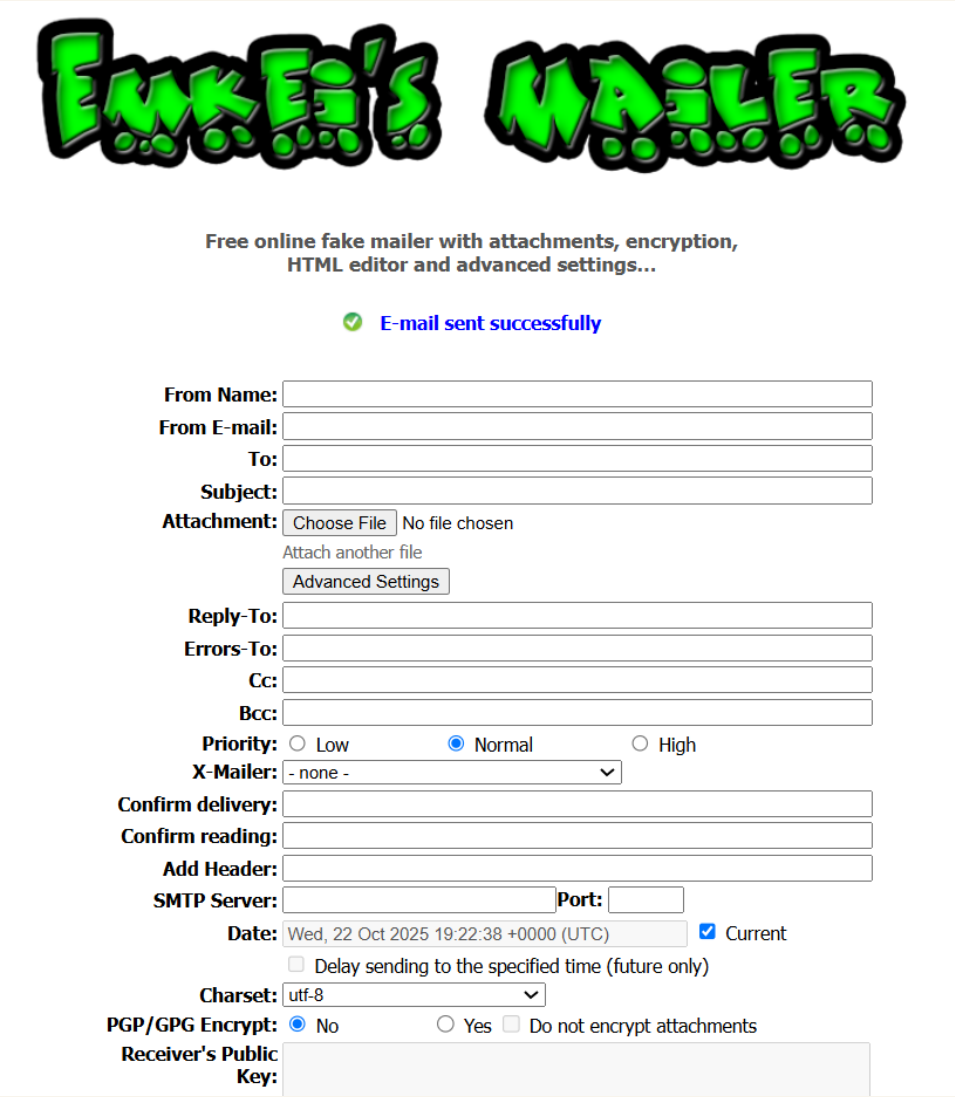
- **Purpose & engine:** web tool (plus paid API) to test **email/newsletter quality,** backend = **Apache SpamAssassin**, providers' filters differ
- **Workflow:** open site -> get **random test address** -> send the email -> receive a **score (0-10), positive = good**, **negative = bad**, detailed report kept **7 days** (or **30 days** when logged in)
- **Checks - message:** text version and source
- **Checks - SpamAssassin:** overall spam score *(below -5 considered spam)*
- **Checks - authentication: SPF**, **DKIM**, **DMARC**, server <-> website association, domain <-> mail-server association, hostname assignment
- **Checks - formation & reputation:** image validation, content safety, URL shortener use, List-Unsubscribe header, and IP blocklist status



ANALYSIS OF THE SELECTED TOOLS FOR EXPERIMENTATION

EMKEI'S MAILER

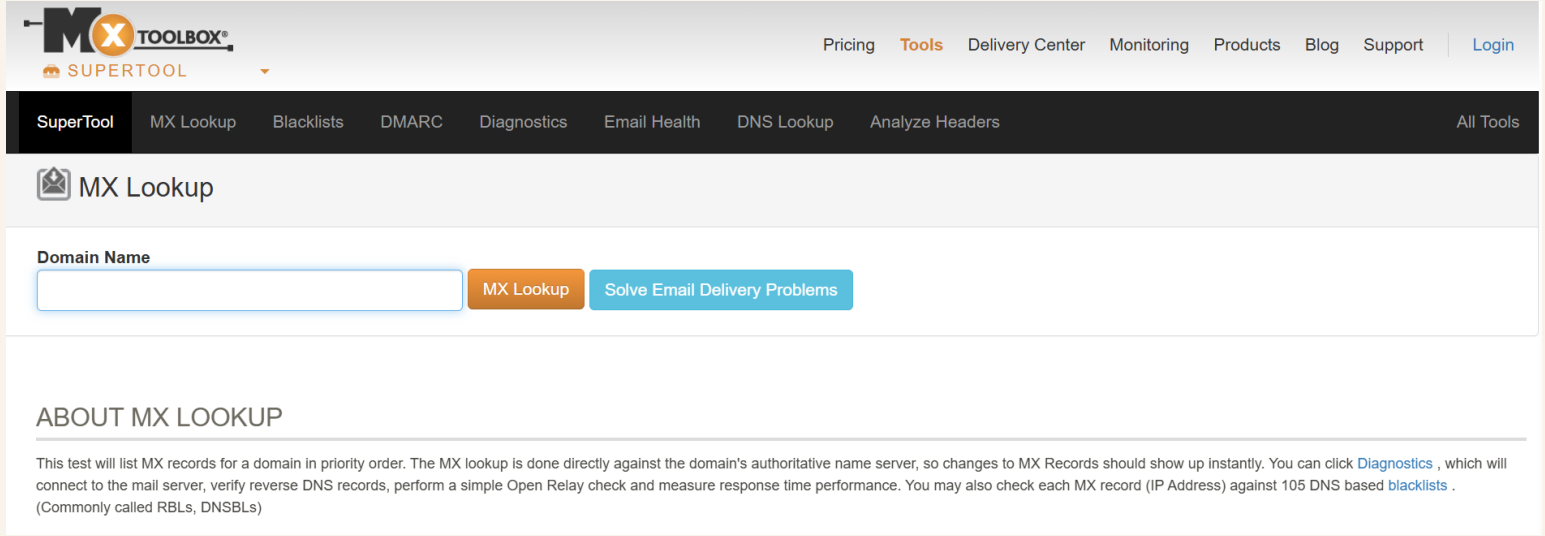
- **What it is:** web tool for sending **fake/simulated emails** for testing, supports HTML editor, attachments, custom headers, and encryption
- **Use in project:** baseline for spoofed-sender tests, comparison against authenticated senders and Mail-Tester results
- **Main form fields: From name**, **From e-mail**, **To**, **Subject**, **Attachment**, **Content-Type**, **Text**
- **Advanced fields: Reply-To**, **Errors-To**, **Cc**, **Bcc**, **Priority**, **X-Mailer**, **Confirm delivery**, **Confirm reading**, **Add header**, **SMTP Server**, **Port**, **Date**, **Charset**, **PGP/GPG encrypt**, **Receiver's public key**
- **Transport options:** custom **SMTP server** and **Port**, optional **Confirm delivery** and **Confirm reading**
- Tool can imitate senders, only for **controlled tests**



ANALYSIS OF THE SELECTED TOOLS FOR EXPERIMENTATION

MXTOOLBOX

- **What it is:** online toolkit for **email structure** and **domain health check** - used to check DNS configs, deliverability, blacklist status, and mail server availability (useful for both **defenders** and **attackers**)
- **Core checks: DNS record lookup** (MX,A,TXT), **SMTP diagnostics** (incl. open-relay test), **Blacklist check** (IP,domain), **Email header analysis** (human-readable format), **Monitoring & alerts** (e.g., setup alerts when domain gets blacklisted)
- **Auth focus:** quick verification of **SPF**, **DKIM**, **DMARC** records, confirm whether third-party senders use **clean (non-blacklisted) Ips**
- **Pros:** wide range of DNS/email tools, **real-time SMTP diagnosis**
- **Cons:** can feel **complex** and hard to navigate
- **Plans: Free (1 domain)**, **Delivery Center ($129/mo)**, **Delivery Center Plus ($399/mo)** with advanced monitoring, threat tools, and higher message & domain limits



EMAILPROFI SETUP (SEZNAM.CZ)

- **Account & domain:** create Seznam account -> register domain *(nikuska.cz)* -> access DNS settings
- **Goal:** make the domain ready for sending/receiving mail and pass basic anti-spam checks
- **Key idea:** correct DNS + authentication = better deliverability

Nastavení | Prodloužení | **Změna DNS** | Osobní údaje

DNS záznamy

Doména	Typ	Data	TTL
@	SOA	ans.emailprofi.cz. hostmaster.seznam.cz. 44 14400 3600 1814400 3600	3600
	MX	10 1af6af85a3151459.mx2.emailprofi.seznam.cz.	1800
	MX	20 1af6af85a3151459.mx1.emailprofi.seznam.cz.	1800
	NS	ams.emailprofi.cz.	1800
	NS	ans.emailprofi.cz.	1800
@	TXT	v=spf1 ipv4:203.0.113.1 -all	1800
_dmarc	TXT	v=DMARC1; p=reject; pct=100; adkim=r; aspf=r	1800
szn20221014._domainkey	CNAME	szn20221014._domainkey.seznam.cz.	1800

+ Vytvořit nový DNS záznam

EMAILPROFI SETUP (SEZNAM.CZ) - SPF

- **What it is:** DNS **TXT** record that lists **which mail servers/IPs can send** for the domain
- **Why:** SMTP does **not** verify the visible "From" (used for identifying whether the email comes from a trusted source), SPF helps detect fake senders
- **How it is checked:** receiver looks up domain's **Return-Path** SPF -> verifies whether **sending IP** is authorized -> pass = accept, fail = spam/reject
- ***Example (EmailProfi):*** *v=spf1 include:spf.seznam.cz ~all*
  - v=spf1 -> tells the server that this is content of SPF record
  - include: -> this tag instructs the server which third-party organizations are authorized to send emails with this specific domain (seznam.cz in my case), this domain is then considered authorized
  - ~all -> this flag tells the server that addresses that are not listed in SPF record will be marked as spam but will be accepted
- **Other flags:** -all (addresses that are not listed in SPF record are not authorized to send emails and therefore should be rejected), +all (tells the server that any server can send email on behalf of the domain)
- Rules: one SPF per domain, must end with all (or use redirect), lowercase only

@	TXT	v=spf1 include:spf.seznam.cz ~all	1800

EMAILPROFI SETUP (SEZNAM.CZ) - DKIM

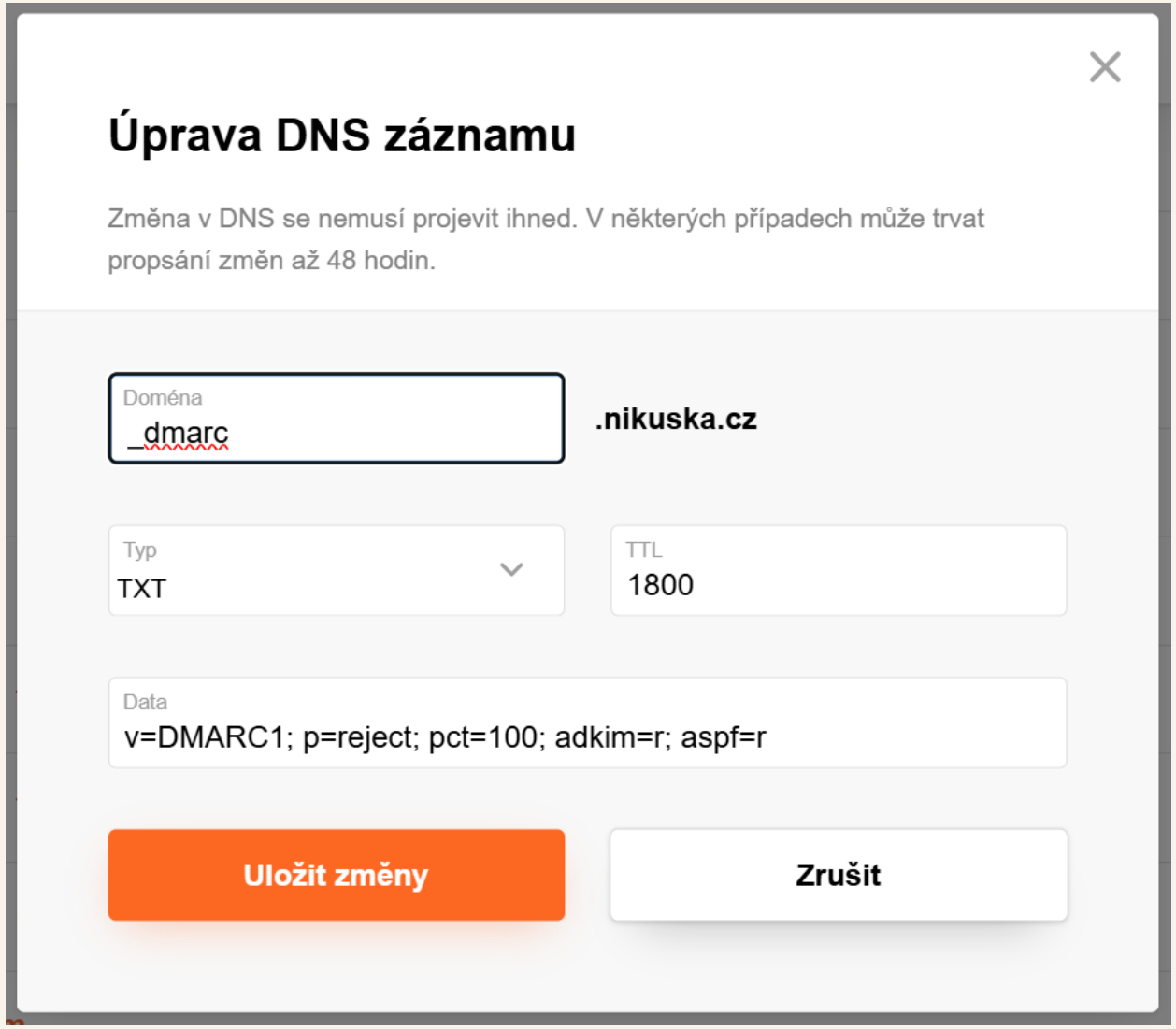
- **What it is:** an authentication method that prevents attackers from impersonating a verified or legitimate domain - sending an email from a domain that does not correspond to the sender
- **Two parts: DKIM record in DNS** (public key) + **DKIM header** in each email (signature)
- **Keys:** provider generates keys, sender signs with **private key**, receivers verify with **public key** from DNS
- **DNS name format:** [selector]._domainkey.[domain] (TXT or CNAME to the key) - selector field is issued by the email service provider used by the domain
- ***Example (EmailProfi CNAME):***
  szn20221014._domainkey CNAME szn20221014._domainkey.seznam.cz. 1800
  - selector = szn20221014
- **Effect:** DKIM check shows if the **body/headers were changed** after sending

szn20221014._domainkey	CNAME	szn20221014._domainkey.seznam.cz.	1800

EMAILPROFI SETUP (SEZNAM.CZ) - DMARC

- **What it is:** DNS **TXT** policy that says **what to do** after SPF & DKIM checks
- **Actions:** deliver, **quarantine** (spam), or **reject** when SPF & DKIM fail
- ***Example:***
  - _dmarc TXT "v=DMARC1; p=quarantine; adkim=r; aspf=r;"

  _dmarc -> subdomain, TXT -> type of DNS record, v=DMARC1 -> DMARC record, p=quarantine -> put failures to spam, adkim=r & aspf=r -> **relaxed** alignment (s for strict)
- **Optional reporting:** rua=mailto:example@example.com to receive **failure reports** and tune the setup



TYPES OF ATTACKS AND THEIR EXECUTION

PHISHING

- **Phishing** = fake messages that look like they come from a trusted company (bank, cloud, delivery)
- **Goal:** make you click a link or open a file and give your password or card data
- **How it works:** mass emails/SMS with urgent text like “Your account is blocked” + link to a fake login page
- **Signs of phishing:** generic hello, spelling mistakes, strange sender, mismatched links, unexpected attachments

TYPES OF ATTACKS AND THEIR EXECUTION

SPEAR PHISHING

- **Spear phishing** = targeted fake messages that look like they come from your boss, colleague, or vendor (use real details about you or your work)
- **Goal:** make one specific person do something (send money, share login, open a file, change payment info)
- **How it works:** attacker checks LinkedIn/company site or past emails, then sends a custom email or replies in a real thread, may spoof the name or a look-alike domain (e.g., micros0ft.com)
- **Signs of spear phishing:** unusual or "urgent/secret" request from a known person, asks to skip normal process, new bank details or gift cards, reply-to/domain mismatch, tone feels slightly off

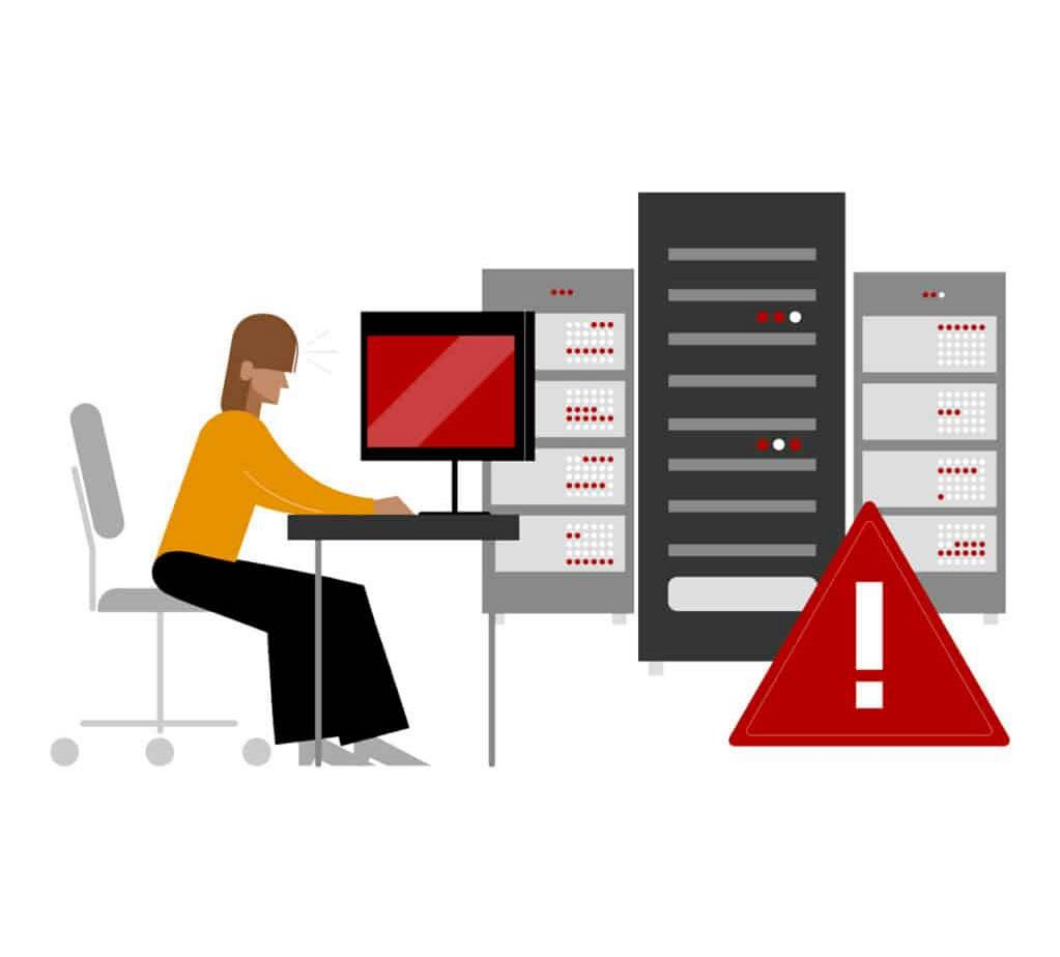
TYPES OF ATTACKS AND THEIR EXECUTION

SPOOFING

- **Spoofing** = pretending to be someone or something else (email, phone number, website, or system) to gain trust
- **Goal:** trick people or systems to trust the message, steal data or money, or bypass security checks
- **How it works:** attacker forges the sender/identity - fake “From” email, caller-ID, or look-alike domain (e.g., paypal.com), may also fake network info (IP/MAC) to redirect traffic
- **Signs of spoofing:** display name looks right but the full address/number is odd, reply-to or domain mismatch, tiny spelling changes in the URL, unexpected “urgent” requests, browser warns about certificate/HTTPS

TYPES OF ATTACKS AND THEIR EXECUTION

DENIAL-OF-SERVICE



- **Denial-of-Service (DoS)** = making a website/app/server so busy that real users cannot use it
- **Goal:** cause outages or slowdowns, disrupt business, or distract defenders
- **How it works:** attacker floods the target with huge traffic or heavy requests - often from many hacked machines (a botnet)
- **Signs of DoS:** site very slow or down, many timeouts/5xx errors, sudden spikes in bandwidth/CPU, lots of requests from many IPs (or one region), same URL hit repeatedly, monitoring alerts

TYPES OF ATTACKS AND THEIR EXECUTION

TROJAN HORSE

- **Trojan horse** = a bad program that looks like a normal app or file (game, PDF, update), you install/run it yourself
- **Goal:** steal data or passwords, spy on you, install more malware, or give the attacker remote control
- **How it works:** sent as an attachment/link, "free/cracked" software, fake update/installer, or malvertising, when opened, it installs a hidden backdoor and talks to the attacker's server
- **Signs of trojan:** unknown apps/processes, PC suddenly slow or hot, new startup items, disabled antivirus, strange network traffic, browser redirects, pop-ups you didn't expect

REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS

- All combinations of 3 email types x 4 sender addresses (12 tests)
- **Sender addresses (4):** personal, fake (via emkei's sender), emailprofi with correct DNS, emailprofi with incorrect DNS
- **Email types (3):** normal text body, "100% spam-detected" text, spam-like message
- **Goal:** measure the Mail-Tester score for each combination and report the results

REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS

VALID TEXT	Hi, how are you? Long time no see. Nikola
SPAM DETECTED TEXT	H XJS*C4JDBQADN1.NSBN3*2IDNEN*GTUBE-STANDARD-ANTI-UBE-TEST-EMAIL*C.34X
LOOK LIKE SPAM TEXT	Hello mister, I would like to report a virus on your computer. You probably clicked on a link in a spam email. Reply to: spam@spamcenter.com

REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS

PERSONAL EMAIL	nika.sasinkova@gmail.com
FAKE EMAIL	test@spam.com
DNS SETUP CORRECT	nikinka@nikuska.cz @ TXT v=spf1 include:spf.seznam.cz ~all 1800 _dmarc TXT v=DMARC1; p=reject; 1800 szn20221014._domainkey CNAME szn20221014._domainkey.seznam.cz. 1800
DNS SETUP INCORRECT	nikinka@nikuska.cz @ TXT v=spf1 ip4:203.0.113.1 -all 1800 _dmarc TXT v=DMARC1; p=reject; pct=100; adkim=r; aspf=r 1800 szn20221014._domainkey CNAME szn20221014._domainkey.seznam.cz. 1800

REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS

	PERSONAL EMAIL	DNS SETUP CORRECT	DNS SETUP INCORRECT	FAKE EMAIL
Valid text	10	10	7	8
Spam detected text	0	0	0	0
Look like spam text	10	10	7	8

REPORT FROM MAIL-TESTER WITH NORMAL, AND FAKE EMAILS

- **Score meaning:** Mail-Tester **0-10**, **10** = clean/authenticated, **7-8** = some auth issues, **0** = blocked as spam
- **Personal email (valid & spam-like): 10/10**, **deductions: 0 points**
- **Own domain, DNS correct (valid & spam-like): 10/10**, **deductions: 0 points**
- **Own domain, DNS incorrect (valid & spam-like): 7/10**, **deductions: -3 points total** - Mail-Tester cites **SPF fail (unauthorized IP 77.75.76.89)**
- **Fake sender via Emkei: 8/10**, **deductions: -2 points total** -> **-1** for **SPF** (unauthorized IP **114.29.236.247**), **-1** for **missing DKIM**
- **Known-spam body (GTUBE) for all senders: 0/10**, **deductions: -10 points** - flagged by **SpamAssassin** signature regardless of DNS/authentication

SOURCE CODE FOR ANALYZING EMAIL HEADERS IMPLEMENTED IN PYTHON

```python
#!/usr/bin/env python3

from email import policy
from email.parser import BytesParser
from typing import Any
import argparse
import json

TARGET_HEADERS = [
    "From", "To", "Delivered-To", "Deliver-To", "Subject",
    "Reply-To", "Return-Path", "Received", "Message-ID",
    "DKIM-Signature", "Authentication-Results"
]

def parse_email_headers(file_path) -> dict[Any, Any]:  1 usage
    with open(file_path, 'rb') as f:
        msg = BytesParser(policy=policy.default).parse(f)

    extracted = {}

    for header in TARGET_HEADERS:
        if header == "Received":
            extracted[header] = msg.get_all("Received") or []
        else:
            extracted[header] = msg.get(header) or None

    spf_result = None
    auth_results = extracted.get("Authentication-Results")
    if auth_results and "spf=" in auth_results.lower():
        for part in auth_results.split(";"):
            part = part.strip()
            if part.lower().startswith("spf="):
                spf_result = part
                break
```

```python
    extracted["SPF"] = spf_result
    extracted["DKIM"] = extracted.pop("DKIM-Signature")

    return extracted

def main() -> None:  1 usage
    parser = argparse.ArgumentParser(
        description="Analyze email headers from a .eml file."
    )

    parser.add_argument(
        *name_or_flags: "file_path",
        help="Path to the .eml file"
    )

    args = parser.parse_args()

    result = parse_email_headers(args.file_path)
    print(json.dumps(result, indent=4, default=str))

if __name__ == "__main__":
    main()
```

- **Purpose:** quick, offline **header audit** of a .eml file - checks who sent the mail, how it traveled, and auth hints
- **What it extracts:** From, To, Delivered-To, Deliver-To, Subject, Reply-To, Return-Path, all Received lines, Message-ID, Authentication-Results, and DKIM, it also parses SPF from Authentication-Results
- No internet or mailbox access required, works on any saved email with full headers

SOURCE CODE FOR ANALYZING EMAIL HEADERS IMPLEMENTED IN PYTHON

```
C:\Users\nikola\PycharmProjects\PythonProject1\.venv\Scripts\python.exe C:\Users\nikola\PycharmProjects\PythonProject1\SasinkovaNikola_PIB.py C
{
    "From": "Reserved <newsletter@message.reserved.com>",
    "To": "Nikola \u0160a\u0161inkov\u00e1 <nika.sasinkova@gmail.com>",
    "Delivered-To": "nika.sasinkova@gmail.com",
    "Deliver-To": null,
    "Subject": "Everyday Comfort",
    "Reply-To": null,
    "Return-Path": "<30774=9c3feee2-6f35-4763-94f9-8fb27815f02e=133=14242662@e.message.reserved.com>",
```

```
    "Received": [
        "by 2002:a05:651c:2159:b0:32c:9f07:dd8a with SMTP id m25csp4009809ljc;        Mon, 25 Aug 2025 00:40:22 -0700 (PDT)",
        "from ip1.message.reserved.com (ip1.message.reserved.com. [195.192.241.21])        by mx.google.com with ESMTPS id a640c23a62f3a-afe78
        "by ip1.message.reserved.com id hlg9mc3b29so for <nika.sasinkova@gmail.com>; Mon, 25 Aug 2025 07:40:21 +0000 (envelope-from <30774=9c3
    ],
    "Message-ID": "<30774=9c3feee2-6f35-4763-94f9-8fb27815f02e=133=14242662@links.message.reserved.com>",
    "Authentication-Results": "mx.google.com;       dkim=pass header.i=@fbl-expertsender.com header.s=googlefbl header.b=JGtsjj84;       dkim=
    "SPF": "spf=pass (google.com: domain of 30774=9c3feee2-6f35-4763-94f9-8fb27815f02e=133=14242662@e.message.reserved.com designates 195.192.
    "DKIM": "v=1; a=rsa-sha256; c=relaxed/relaxed; q=dns/txt; d=fbl-expertsender.com; s=googlefbl; h=Date:Subject:From:To:X-CSA-Complaints:Lis
}
```

PLAN FOR CONTINUING THE PROJECT

2ND PROGRESS REPORT

Detailed reports from MXToolbox including a comparison between fully functioning and malfunctioning DNS record setups

2ND PROGRESS REPORT

Description of spam filters, practical recommendations on how to remain safe

2ND PROGRESS REPORT

Source code for sending an email with Python

FINAL PROJECT SUBMISSION

Comprehensive project description, explanation of the vocabulary required to understand how email works, my setup of the required tools

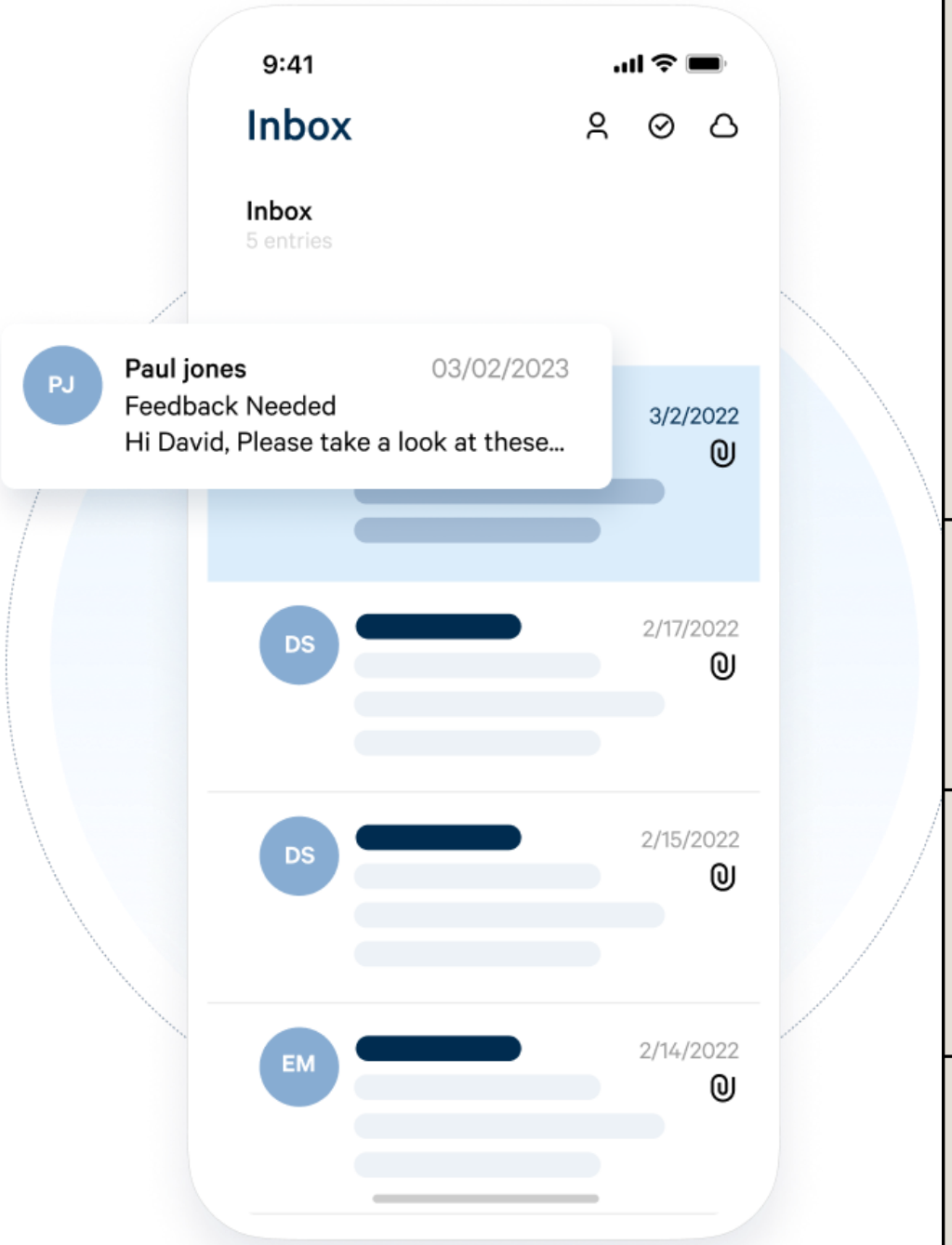
FINAL PROJECT SUBMISSION

Description of the security of TLS and E2EE, comprehensive reports from the performed tests, accompanying Python source code

YEAR 2025

SOURCES

- https://www.itarian.com/blog/wp-content/uploads/2025/07/how-too-spoofing-hacking.png, 10.10.2025.
- https://proxyelite.info/wp-content/uploads/2023/12/ddos-distributed-denial-of-service-1024x1024.jpg, 10.10.2025.
- https://miro.medium.com/v2/resize:fit:1040/0*tDAka8iaF6xFFb59.png, 10.10.2025.
- https://vipre.com/wp-content/uploads/2022/11/spear-phishing.jpeg, 10.10.2025.
- https://www.malwarebytes.com/wp-content/uploads/sites/2/2024/05/phishing.webp?w=1024, 10.10.2025.
- https://is1-ssl.mzstatic.com/image/thumb/PurpleSource116/v4/e7/d1/a1/e7d1a134-6834-b54c-cc5c-24e91c706da7/2513b58d-1220-4d91-8214-1d3cdbdfd131_3.png/300x0w.jpg, 10.10.2025.
- https://www.inbox.com/images/features.png, 10.10.2025.
- https://support.microsoft.com/images/en-us/989a4585-6091-4512-a148-d3d845651107, 10.10.2025.



THANK YOU

NIKOLA ŠAŠINKOVÁ

XSASINKOVA@STUBA.SK

+421 905 757 920